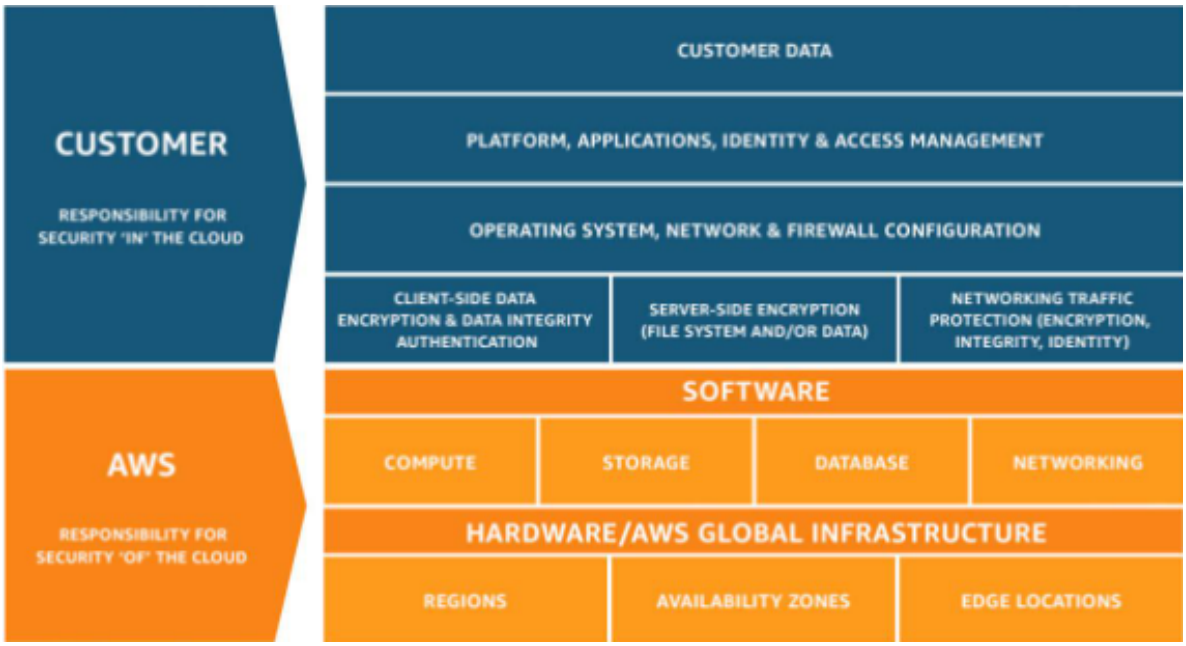
Ferramentas e características para segurança na nuvem

Modelo de Responsabilidade Compartilhada

Dentro da AWS, assim como nas outras empresas que atuam com a oferta de computação em nuvem, existe a necessidade de se estabelecer as responsabilidades a quem são endereçadas. Para a AWS, este processo recebe o nome de Modelo de Responsabilidade Compartilhada.

O modelo é dividido em duas partes: a primeira descreve quais são as responsabilidades da nuvem e, portanto, são relativas a deveres e responsabilidades da própria AWS como provedor de computação em nuvem. O consumidor, ou seja, o cliente AWS tem suas responsabilidades descritas na segunda porção, representada pelos quadros de cor laranja e relacionados como sendo responsabilidades na nuvem.

Figura 1: Modelo de Responsabilidade Compartilhada AWS



Fonte: https://aws.amazon.com/pt/compliance/shared-responsibility-model/

(Acesso em 04/08/2022)

O estabelecimento das responsabilidades é algo inerente à computação em nuvem e tem por objetivo tornar a plataforma mais segura para provedor e cliente, além de salvaguardar ambos os lados. No que diz respeito ao provedor, existem detalhes do uso do serviço que devem ser observados pelo cliente e que, quando negligenciados, tornam seu próprio ambiente vulnerável.

Situações como compartilhamento de senhas indiscriminado ou até mesmo quando existe a hospedagem de conteúdo protegido sob direitos autorais enaltecem a importância deste modelo e fazem com que tanto o provedor quanto a empresa devam construir uma relação de apreciação, de tal forma que o modelo passe a ser a operação padrão em ambos os lados. Assim, o Modelo de Responsabilidade Compartilhada auxilia a reduzir problemas e encargos operacionais.

Vale ressaltar que as responsabilidades elencadas pelo modelo não dizem respeito apenas ao seu uso dentro do que se tem como legal, legítimo e envolve também quais processos estão nas competências do usuário e da AWS. Desta forma, o usuário dos serviços em nuvem da AWS deve

compreender que cada sistema utilizado poderá apresentar especificidades em relação às suas responsabilidades. Podemos compreender melhor a divisão de responsabilidades a seguir:

- **Responsabilidade da AWS:** "segurança da nuvem": a AWS é responsável por proteger a infraestrutura que executa todos os serviços oferecidos na Nuvem AWS. Essa infraestrutura é composta por hardware, software, redes e instalações que executam os Serviços de nuvem AWS. (AWS 2022, Documento Online).

- **Responsabilidade do cliente:** "segurança na nuvem": a responsabilidade do cliente será determinada pelos Serviços de nuvem AWS selecionados por ele. Isso determina a quantidade de operações de configuração que o cliente deverá executar como parte de suas responsabilidades de segurança. Por exemplo, um serviço como o Amazon Elastic Compute Cloud (Amazon EC2) é categorizado como Infrastructure as a Service (IaaS – Infraestrutura como serviço) e, dessa forma, exige que o cliente execute todas as tarefas necessárias de configuração e gerenciamento da segurança. (AWS 2022, Documento Online).

A segurança online é um tema que vem preocupando muitas empresas e movimentando o setor de desenvolvimento de sistemas. Além disso, existe um fator, dentro deste tema, que ainda é extremamente difícil de se contornar: o fator humano e seu impacto na segurança. O comportamento humano tende a oferecer casos e situações de falha de segurança em sistemas na nuvem e é por este motivo que o modelo de responsabilidade compartilhada vem a ser tão importante.

Autenticação Multifator (MFA)

Sendo o modelo de responsabilidade compartilhada uma espécie de contrato onde cliente e provedor estabelecem suas competências na busca

por um ambiente virtual seguro, podemos dizer que é apenas um dos diversos sistemas de segurança. Complementando este modelo temos o IAM, o Gerenciador de Identidade e Acesso que, dentre outras funcionalidades, oferece o recurso da Autenticação Multifator (MFA). Dentro do IAM é possível habilitar o recurso para qualquer usuário, inclusive o usuário raiz. Com isso, temos a criação de uma autenticação específica, o que aumenta a segurança de toda a conta. A Autenticação Multifator apresenta como componentes os dispositivos MFA virtuais, as chaves de segurança U2F, o hardware MFA e o MFA baseado em mensagem de texto SMS.

Dispositivos de MFA Virtuais são aplicativos que simulam dispositivos físicos. Em seu funcionamento, o dispositivo emite um código numérico de 6 dígitos criado por um algoritmo. Para o acesso com este recurso ao gerenciador AWS, o usuário usa seu código validado por seu dispositivo em uma página da web. Os códigos MFA são atribuídos a apenas um único usuário cada.

Sobre as chaves de segurança U2F, temos um dispositivo, que deve ser conectado a uma porta USB e que usa um padrão FIXO de código aberto. O login é feito com o uso da chave de segurança U2F fisicamente conectada.

A autenticação multifator pode ser realizada com o uso de hardware específico. Quando inserido o hardware multifator é gerado um código numérico com 6 dígitos que deve ser digitado pelo usuário no campo de autenticação de sua página de login. Em um processo de login multifator, um usuário não pode usar o código de 6 dígitos do dispositivo de outro usuário, pois os dispositivos são atribuídos de forma exclusiva ao usuário AWS.

AWS Identity and Access Management (IAM)

Em conjunto com o modelo de responsabilidade compartilhada, a AWS oferece um sistema de controle de acesso e identidade de alta disponibilidade denominado IAM (Identity and Access Management). Com

este sistema o usuário raiz pode criar outros usuários e lhes conceder acesso a todos os serviços AWS ou apenas a serviços específicos.

Dentro da gestão de identidades, o IAM oferece ao gestor da conta raiz a possibilidade de criar diferentes níveis de acesso a determinado sistema, por exemplo, uma identidade pode ser criada para dar acesso somente a leitura a instâncias do EC2, enquanto outra identidade pode oferecer a possibilidade de alterar dados e informações de um bucket do S3 sem permitir que tal bucket seja excluído.

Até mesmo para um serviço de segurança existem melhores práticas de segurança oferecidas pela AWS e que, no caso do IAM, uma das principais é relativa aos cuidados com o usuário raiz. Nesta orientação de segurança, a AWS recomenda que o usuário raiz seja utilizado o mínimo possível.

Contas de usuário administrativas podem ser criadas, mas para o uso diário é recomendado que sejam criados usuários com somente os sistemas e atribuições que serão utilizados. O quadro a seguir sintetiza alguns dos recursos do IAM:

Quadro 1: Recursos do IAM

Acesso compartilhado a conta AWS	O usuário raiz pode conceder permissões a outras pessoas para administrar e usar recursos em sua conta da AWS sem a necessidade de compartilhar sua senha ou chave de acesso.
Permissões granulares	O usuário raiz pode conceder permissões diferentes a pessoas diferentes para diferentes recursos.
Acesso seguro a Instâncias do EC2	O usuário raiz pode usar recursos do IAM para fornecer credenciais de forma segura às aplicações que são executadas em instâncias do EC2. Essas credenciais fornecem permissões ao aplicativo para acessar outros recursos da AWS.

Autenticação multifator (MFA)	O usuário raiz pode adicionar a autenticação de dois fatores à sua conta e a usuários individuais para proporcionar segurança extra. Com a MFA, você ou seus usuários devem fornecer não apenas uma senha ou chave de acesso para trabalhar com a sua conta, mas também um código de um dispositivo especialmente configurado.
Federação de identidades	O usuário raiz pode permitir que os usuários que já têm senhas em outro lugar, por exemplo, em sua rede corporativa ou com um provedor de identidade de Internet, obtenham acesso temporário à sua conta da AWS.
Finalmente consistente	O IAM, como muitos outros produtos da AWS, oferece consistência final. O IAM atinge alta disponibilidade ao replicar dados em vários servidores dentro de datacenters da Amazon em todo o mundo.

Fonte: AWS (2021a, p.02).

O IAM oferece estes diversos recursos de forma gratuita, em conjunto com o AWS Security Token Service (AWS STS), ou seja, sem qualquer custo adicional, sem restrições eventuais ou limites de uso. Mas, fica a ressalva que o IAM oferece controle de acesso a sistemas AWS que possuem custo, portanto, embora seu controle de autenticação não seja cobrado, estes serviços serão.

AWS WAF

Uma das táticas de controle de ciberataques está na limitação dos canais de conexão, das portas lógicas de um computador, fazendo com que exista somente um canal para a saída e entrada de dados. A este canal é aplicado um sistema, ou hardware capaz de analisar este tráfego e barrar atividades irregulares. A este serviço damos o nome de Firewall.

A AWS possui seu próprio Firewall, o AWS WAF, um serviço que monitora as solicitações HTTP de serviços como o Amazon CloudFront, "[...] API REST do Amazon API Gateway, um Application Load Balancer ou um AWS

AppSync A API GraphQL." (AWS 2022a, p.07).

Diferente de firewalls tradicionais, o AWS WAF também controla e protege o conteúdo do usuário. Em suas configurações, o usuário pode aplicar uma série de definições quanto aos endereços IP autorizados a realizar solicitações e até mesmo valores de strings de consulta. Com sua personalização, uma página específica de erro pode ser exibida, em serviços como o CloudFront, quando o sistema detecta e realiza algum bloqueio. Aplicações também podem ser protegidas pelo AWS WAF, principalmente as que são hospedadas em contêineres do Amazon Elastic Container Service (ECS). A integração entre o ECS e o WAF ocorre através do load balancer.

AWS Key Management Service

A criptografia é a capacidade de um sistema em utilizar um algoritmo para criar chaves que tornem seguro o acesso a determinado sistema. Na AWS a criação de chaves criptografadas ocorre com o sistema AWS Key Management Service (KMS), que além de criar tais chaves, permite o gerenciamento de seu uso. De acordo com AWS (2022b, documento online):

> O AWS KMS é um serviço seguro e resiliente que usa módulos de segurança de hardware validados ou em processo de validação pelo FIPS 140-2 para proteger suas chaves. O AWS KMS é integrado ao AWS CloudTrail para fornecer logs contendo toda a utilização das chaves para ajudar a cumprir requisitos normativos e de compatibilidade. (AWS 2022b, Documento Online).

A esmagadora maioria dos serviços AWS que utilizam criptografia se integram ao AWS KMS, por exemplo, o CloudTrail, que em sua aplicação faz o registro dos logs de uso das chaves criadas no KMS, uma demanda em momentos de auditoria e conformidade. O uso deste serviço aprimora o

controle do usuário sobre os dados criptografados.

Atividade Extra

Vídeo: "AWS Webinar - Segurança em Aplicações Web.
Link: https://www.youtube.com/watch?v=J5GMLY-3Vpk **(Acesso em 04/08/2022)**

Referência Bibliográfica

AWS. **AWS Identity and Access Management:** Guia do usuário. 2021. Disponível em: <https://docs.aws.amazon.com/pt_br/IAM/latest/UserGuide/iam-ug.pdf#id_credentials_mfa> **(Acesso em 04/08/2022)**

AWS. **AWS Identity and Access Management:** Guia do usuário. 2021a. Disponível em: <https://docs.aws.amazon.com/pt_br/IAM/latest/UserGuide/iam-ug.pdf#introduction> **(Acesso em 04/08/2022)**

AWS. **AWS Key Management Service (AWS KMS)**. 2022b. Disponível em: < https://aws.amazon.com/pt/kms/> **(Acesso em 04/08/2022)**

AWS. **AWS Key Management Service:** Guia do desenvolvedor. 2022c. Disponível em: <https://docs.aws.amazon.com/pt_br/kms/latest/developerguide/kms-dg.pdf#overview> **(Acesso em 04/08/2022)**

AWS. **AWS WAF, AWS Firewall Manager, e AWS Shield Advanced**: Guia do desenvolvedor. 2022a. Disponível em: <https://docs.aws.amazon.com/pt_br/waf/latest/developerguide/waf-dg.pdf#waf-chapter > **(Acesso em 04/08/2022)**

AWS. **Modelo de responsabilidade compartilhada.** 2022. Disponível em: < https://aws.amazon.com/pt/compliance/shared-responsibility-model/ > **(Acesso em 04/08/2022)**

Atividade Prática - Ferramentas e características para segurança na nuvem

Título da Prática: A importância do controle de credenciais e perfis de acesso na nuvem.

Objetivos: Compreender a segurança oferecida por ferramentas como o IAM da AWS no controle de acesso aos recursos da nuvem.

Materiais, Métodos e Ferramentas: Acesso ao Console AWS e a ferramenta do IAM.

Atividade Prática

A grande maioria das empresas está migrando seu TI para a nuvem, principalmente quando chega a hora de fazer algum investimento em computadores e outros hardwares. A nuvem tem sido uma escolha fácil pois dá acesso a empresa aos recursos que precisa, e no caso da AWS sem ter que contratar pacotes maiores que sua necessidade.

São inúmeras as vantagens da computação em nuvem, mas também existem algumas mudanças que devem ser feitas, dentro do escopo da gestão da

infraestrutura e principalmente no que diz respeito ao acesso e consumo de recursos dentro da plataforma AWS.

Por padrão o usuário raiz, aquele criado junto com o cadastro da nova conta AWS, tem a possibilidade de iniciar praticamente todo e qualquer serviço, desde que disponível na Zona de Disponibilidade selecionada, o que pode representar um risco, caso existam usuários com plenos poderes e sem o devido treinamento que inadvertidamente ativem recursos.

Para contribuir a Gestão de TI da empresa que migra para a nuvem, existe o IAM, ou *Identity and Access Management,* o sistema AWS responsável por gerenciar as identidades e o acesso delas aos recursos computacionais e dados que a empresa hospeda na plataforma.

Com o IAM a empresa aloca a cada funcionário, dentro de sua credencial, as atividades e sistemas que ele pode acessar e o que poderá realizar dentro destes sistemas. Dessa forma, um usuário pode ter acesso completo a um sistema como o EC2 e assim poder criar, modificar, copiar ou excluir instâncias, como desejar. Agora outros usuários podem ter apenas um acesso de leitura, e assim serem incapazes de criar instâncias ou modificar dados e parâmetros.

Desafio

Com o acesso a plataforma configurado, a empresa precisa criar os usuários e assim dar acesso aos recursos para os funcionários que deverão atuar na plataforma AWS. Assim, ela utiliza as atribuições de cada cargo e cria grupos e usuários que se limitem a estas atribuições.

Dessa forma, para realizar seu desafio, crie acessos ao console AWS através do IAM para uma equipe de desenvolvedores de sistemas:

1. Crie um **usuário administrativo** com **acesso total** aos recursos AWS, acesse este usuário para continuar e criar os demais usuários;

2. Crie **2 grupos**, um para acesso ao **S3** e o outro para acesso ao **EC2**. Escolha a política full access e aplique em ambos os grupos em seus respectivos sistemas;

3. Crie **6 usuários**, faça a divisão igualmente nos dois grupos criados, ou seja, **3 para o S3 e 3 para o EC2**;

4. Em cada grupo, escolha um usuário e aplique a ele **acesso total** aos recursos da plataforma do outro grupo, portanto, no grupo EC2 um usuário terá full access ao S3, e vice e versa;

5. Por fim, **faça o print**, monte um documento word, envie a comprovação do que criou:

a) O usuário administrativo recém-criado;

b) Grupos criados;

c) Usuários;

d) Acesso à plataforma em um dos grupos criados.

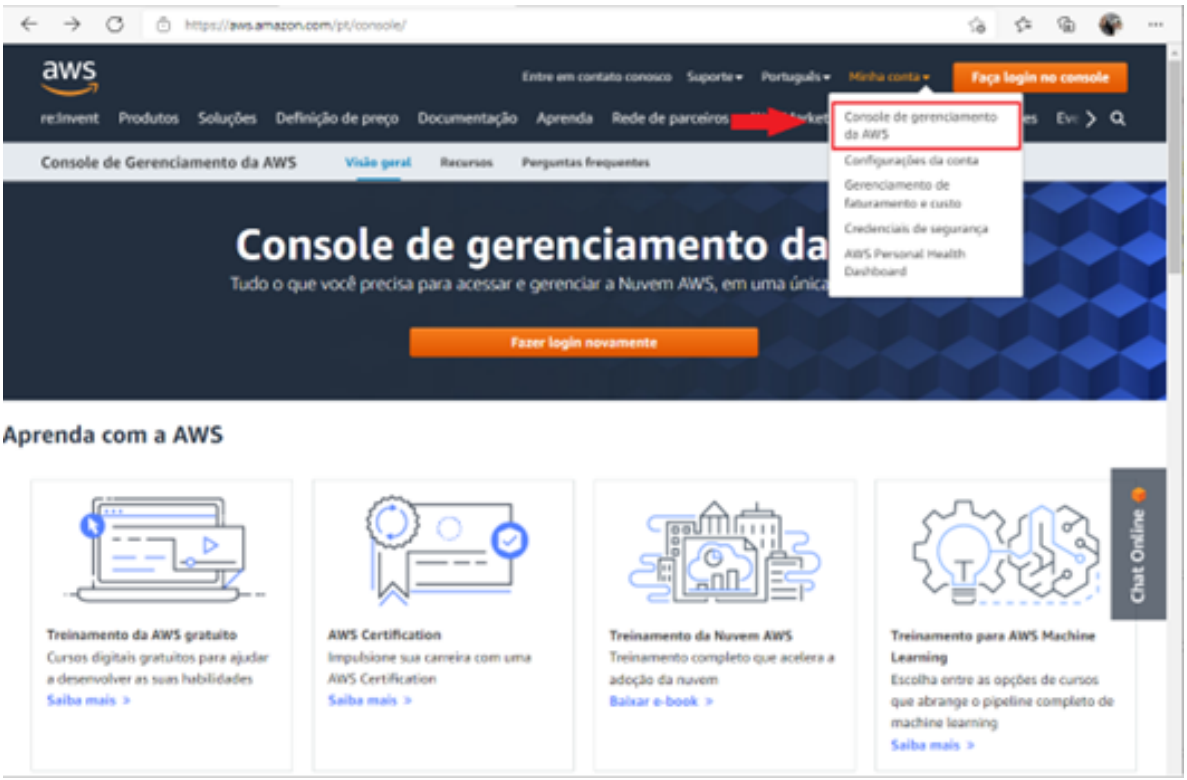
e) Por fim, faça um breve texto relatando como foi sua experiência e quais dificuldades encontrou no processo de criar usuários e alocar políticas.

OBS: Fique livre para a escolha dos nomes dos grupos e usuários, sendo que nos grupos recomendo algum nome que indique o sistema. Quanto aos usuários, recomendo se limitar a uma estrutura de nome e um sobrenome, e dê preferência a nomes fictícios.

Os passos a seguir vão lhe permitir iniciar a atividade, mas lembre-se, você deve criar um arquivo de texto e nele organizar os prints de tela, criando um título do tipo

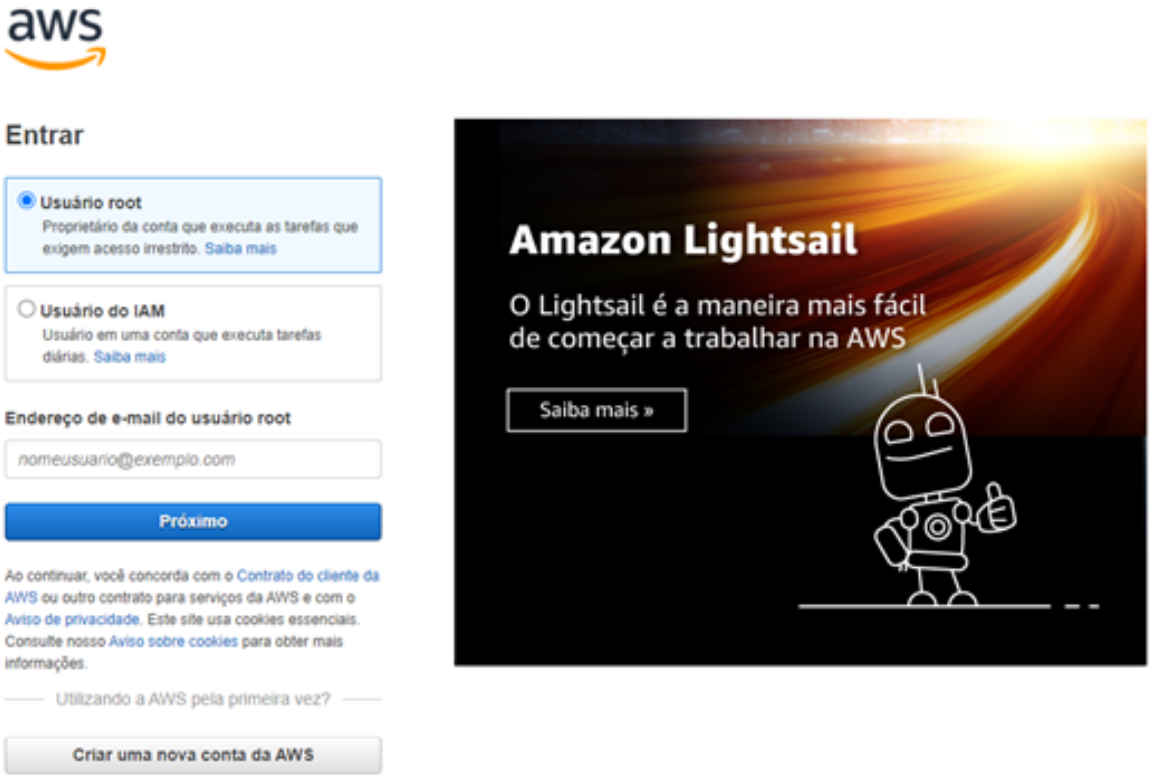
"Figura 1: usuário administrativo."

Passo 1. Para começar sua atividade acesse o portal AWS através do endereço: <www.aws.amazon.com> **(Acesso em 02/08/2022)** e efetue login:



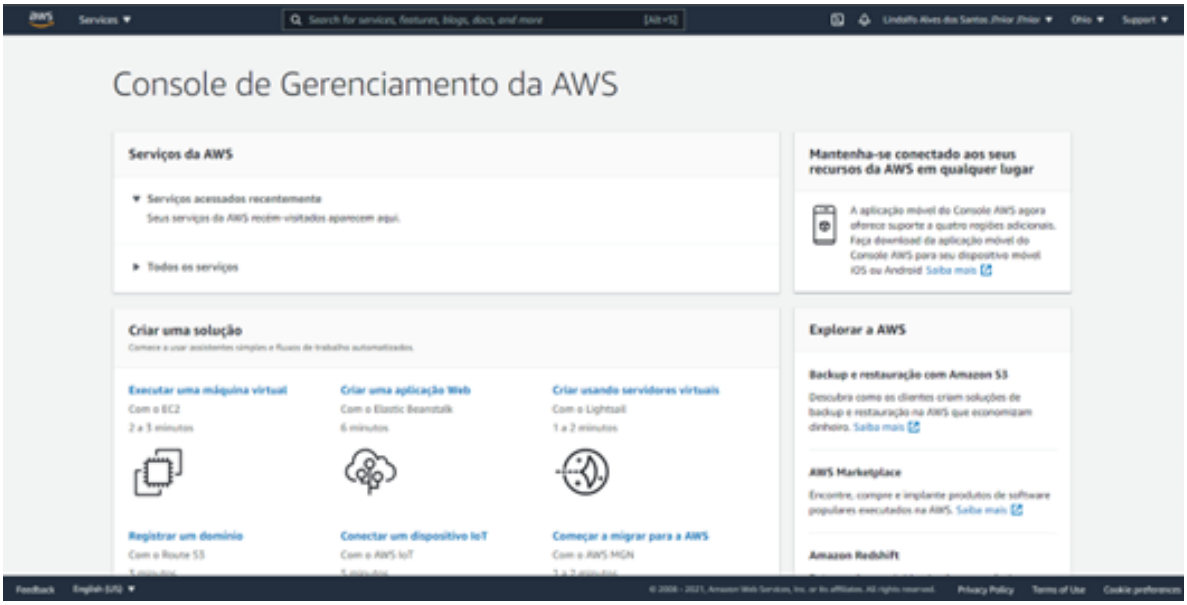
Fonte: Autor (2022)

Na tela seguinte digite a senha de acesso:



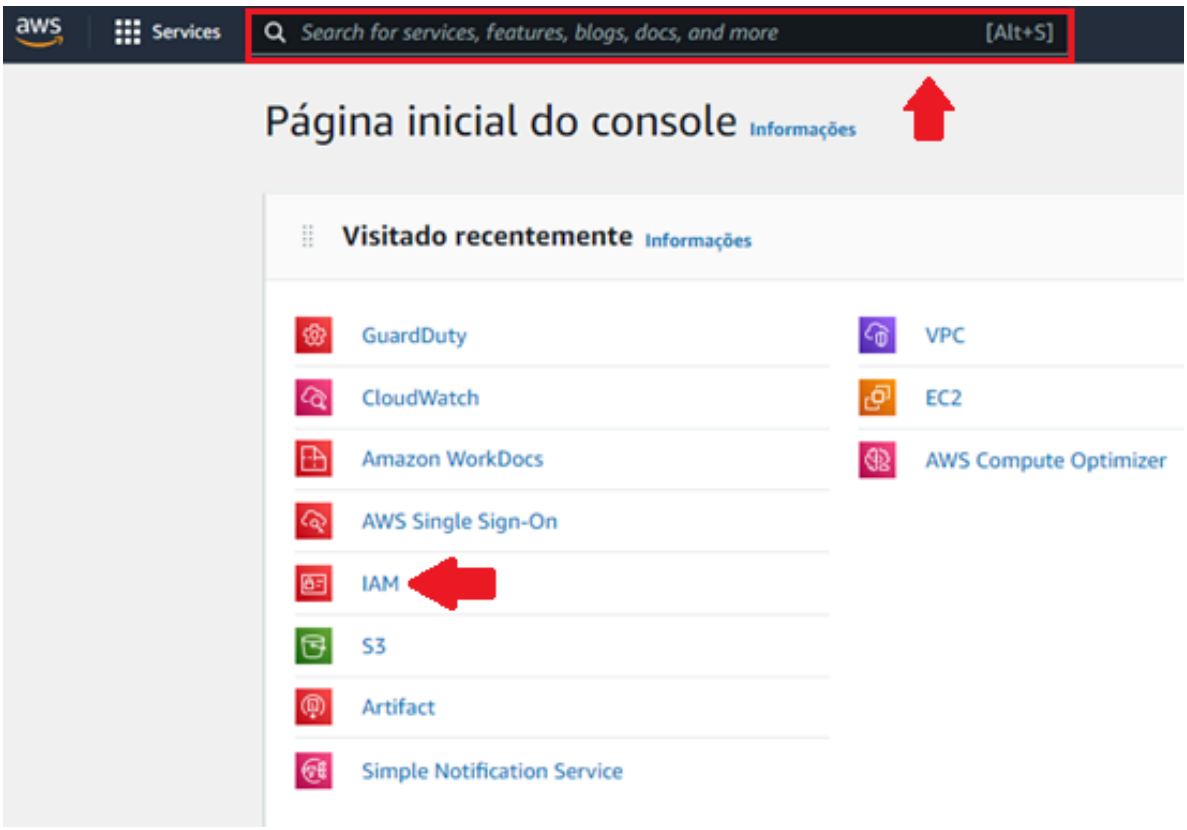
Fonte: Autor (2022)

Passo 2. A página de Console de Gerenciamento de AWS será aberta:



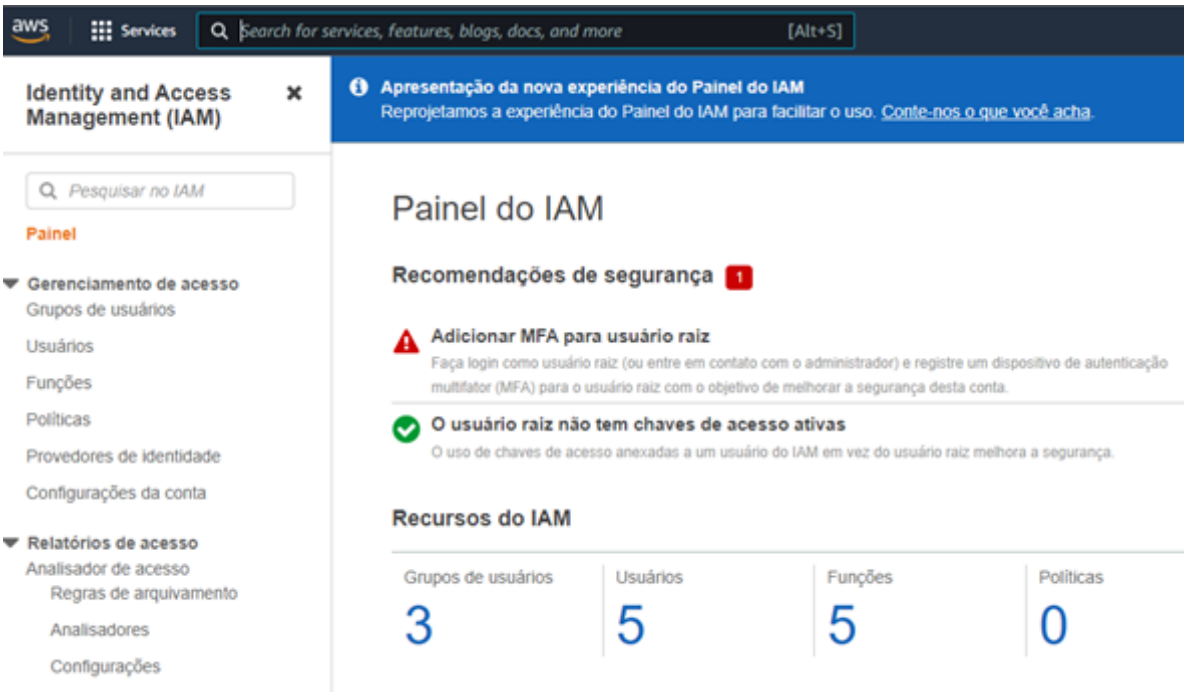
Fonte: Autor (2022)

Passo 3. Uma vez conectado ao Console de Gerenciamento da AWS, pesquise pelo serviço IAM na barra de busca "Search for services, features, blogs, docs and more", ou simplesmente pressione a tecla Alt em conjunto com a letra "S", conforme você pode observar na figura a seguir, na região superior:



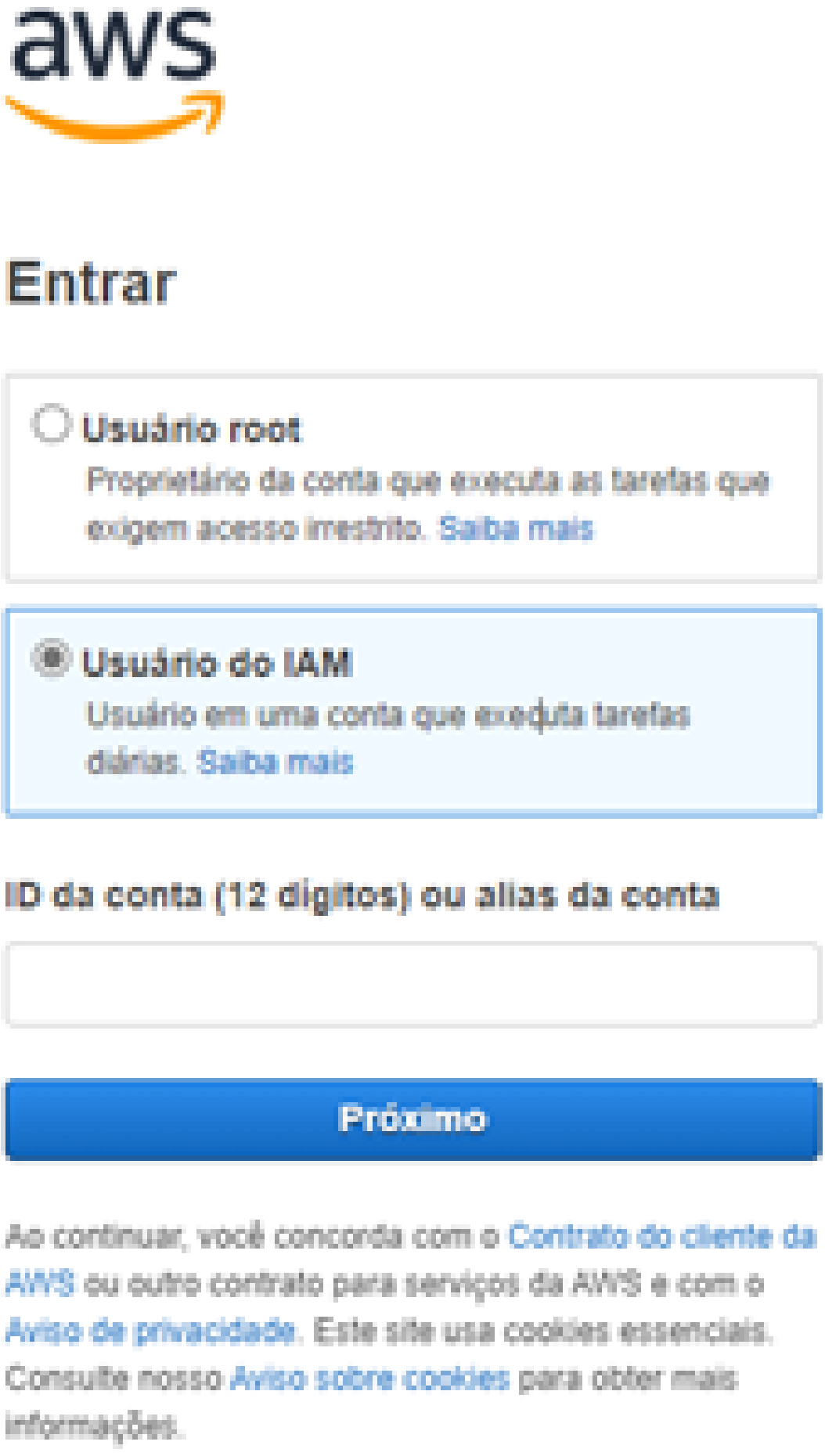
Fonte: Autor (2022)

Passo 4. Para criar Grupos e usuários, basta utilizar as opções do menu "Gerenciamento de acesso" localizado no lado esquerdo do console do IAM, como demonstra a figura a seguir:



Fonte: Autor (2022)

Dica: Após criar os usuários, é exibido o link que este novo usuário deve utilizar para logar em seu console. Caso você saia desta tela, não se preocupe, pois o link fica disponível no lado direito da tela inicial do console do IAM abaixo do item "Conta da AWS" no item "URL de login para usuários do IAM nesta conta" "https://000000000000.signin.aws.amazon.com/console" onde a sequência de 12 números no começo do link representa o ID da conta. Sua outra opção é salvar em algum lugar este número de ID e usar para logar em contas que não são Raiz, na tela normal de login do console AWS, conforme apresenta a figura a seguir, e clicando em "Usuário do IAM:

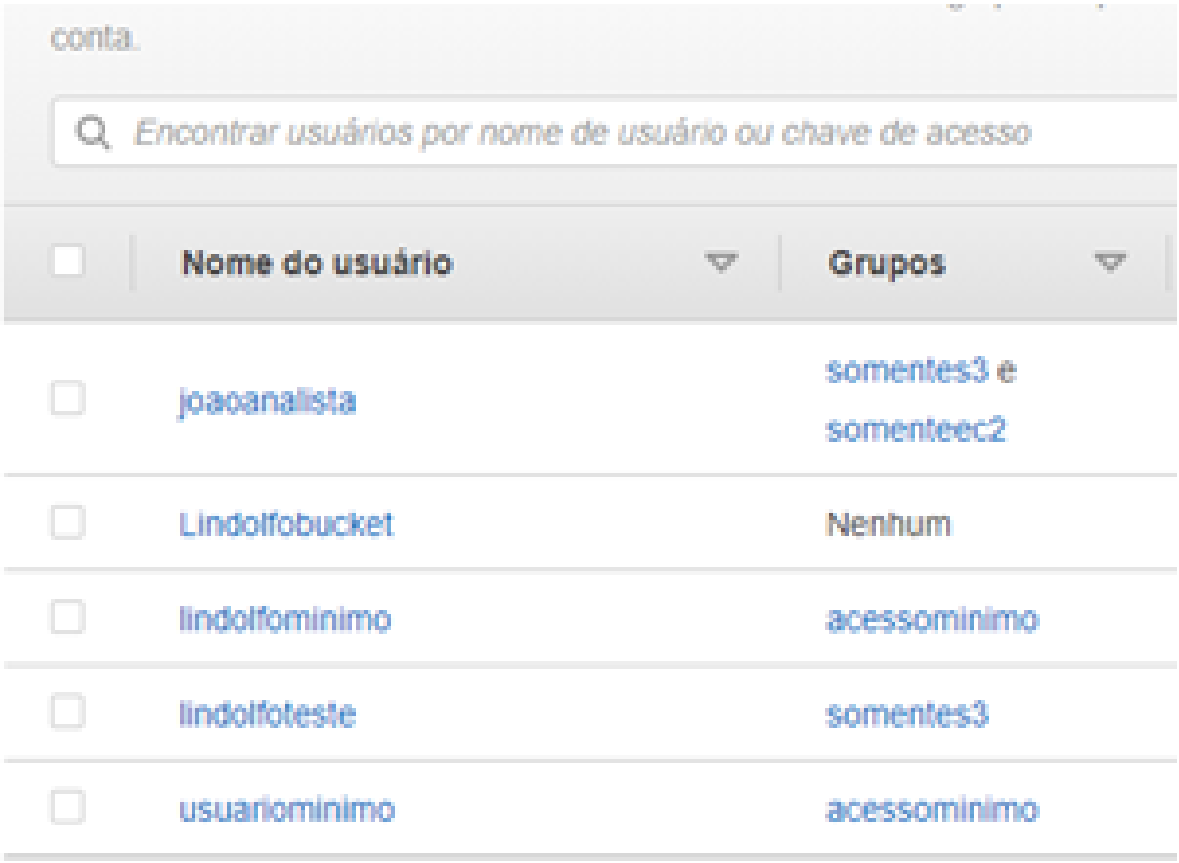


Fonte: Autor (2022)

Passo 5. Para concluir e comprovar o sucesso de sua atividade, envie o print de tela que exiba os usuários criados e a que grupo pertencem.

Gabarito Atividade Prática

Como se trata da criação de grupos, usuários e a aplicação de políticas, o aluno pode comprovar a conclusão com sucesso ao enviar o print de tela com usuários criados e seus respectivos grupos, como o exemplo a seguir:



Ir para exercício